INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103 – RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

MODULE 3 – TECHNICAL RISK TREATMENT

IMPLEMENTING AND VALIDATING SECURITY CONTROLS

ROLE: GRC ANALYST

Organisation: Northbridge Services (Case Study)

Prepared by: Olubunmi Adesanmi

Registration Number: C11/26/CGRCE/17550

Module: GRC103 – Risk Assessment and Management Techniques

Laboratory Environment: Ubuntu Server 24.04 LTS and Kali Linux

Submission Date: 08 November 2026

Version: 1.0

Document Classification: Academic Submission – Controlled Laboratory Environment

TABLE OF CONTENTS

1. Executive Summary
2. Introduction
   2.1 Background
   2.2 Laboratory Scenario
   2.3 Purpose of the Assessment
   2.4 Laboratory Objectives

3. Scope and Limitations
   3.1 Scope
   3.2 Out-of-Scope Activities
   3.3 Limitations
4. Laboratory Environment and Architecture
   4.1 Technical Environment
   4.2 Virtual Machine Configuration
   4.3 Network Architecture
   4.4 Tools and Technologies
5. Risk Assessment Methodology
   5.1 Assessment Approach
   5.2 Risk Identification
   5.3 Risk Scoring Method
   5.4 Risk Classification
6. Baseline Security Assessment
   6.1 Baseline Environment Establishment
   6.2 Exposed-Service Assessment
   6.3 Web Application Assessment
   6.4 Archive Accessibility Assessment
   6.5 Legacy-Service Exposure
   6.6 Initial Risk Register
7. Risk Treatment Strategy 1 – Avoidance
   7.1 Risk Description
   7.2 Treatment Decision
   7.3 Implementation
   7.4 Technical Validation
   7.5 Business Impact and Service Continuity
   7.6 Rollback Considerations
8. Risk Treatment Strategy 2 – Mitigation
   8.1 Archive Protection
   8.2 Nginx Security Configuration
   8.3 File-System Access Restrictions
   8.4 UFW Firewall Implementation
   8.5 Approved-Source Validation
   8.6 Blocked-Source Validation
9. Security Monitoring and Log Correlation
   9.1 Monitoring Objectives
   9.2 Nginx Access Logging
   9.3 Firewall Logging
   9.4 Log Correlation
   9.5 Security Validation Matrix
10. Corrective Controls – Backup and Recovery
   10.1 Recovery Requirements
   10.2 Backup Implementation
   10.3 File-Integrity Verification
   10.4 Simulated Data Loss
   10.5 Restoration

10.6 Recovery Time Measurement
10.7 Backup Limitations
11. Risk Treatment Strategy 3 – Transfer
11.1 Managed Backup Assessment
11.2 Financial Evaluation
11.3 Provider and Customer Responsibilities
11.4 Proposed Contractual Clause
11.5 Third-Party Risk Considerations
12. Risk Treatment Strategy 4 – Acceptance
12.1 Risk Description
12.2 Acceptance Justification
12.3 Acceptance Conditions
12.4 Expiry and Review
13. Financial Analysis and Cost-Benefit Evaluation
13.1 First-Year Cost Assessment
13.2 Option A – Hardening
13.3 Option B – Managed Backup
13.4 Option C – TLS Deployment
13.5 Recommended Investment Combination
13.6 Annual Loss Expectancy
13.7 Financial Benefit Assessment
14. Residual Risk Assessment
14.1 Risk Reassessment
14.2 Residual Risk Register
14.3 Remaining Security Concerns
15. Monitoring and Operational Handover
15.1 Continuous Monitoring Requirements
15.2 Monitoring Responsibilities
15.3 Escalation Requirements
16. Change Management and Rollback
16.1 Change Control
16.2 Implementation Records
16.3 Rollback Procedures
17. Evidence Management and Documentation
17.1 Evidence Collection
17.2 Evidence Integrity
17.3 Evidence Register
18. Management Recommendations
19. Conclusion
20. References
21. Appendices

1. EXECUTIVE SUMMARY

1.1 Overview

This report presents the technical risk treatment and security control implementation exercise conducted for Northbridge Services, a fictional organisation operating an internal document server.

The purpose of the exercise was to identify security weaknesses within the organisation's document server, implement appropriate preventive, detective and corrective controls, and evaluate the effectiveness of the selected risk treatment strategies.

The laboratory was conducted using two virtual machines:

- Ubuntu Server 24.04 LTS, configured as the target document server.
- Kali Linux, configured as the security testing workstation.

The laboratory environment used Nginx, UFW, Python 3, Nmap, curl and Linux backup utilities.

The assessment focused on four primary risks:

1. Exposure of an unnecessary legacy service.
2. Unauthorised access to a directory containing fictional records.
3. Unrestricted incoming network access to the internal document portal.
4. Loss of approved portal content without a demonstrated recovery capability.

1.2 Assessment Activities

The practical exercise followed a baseline-first approach.

The original server configuration was assessed before security changes were introduced. The assessment included service discovery, network connectivity testing, HTTP requests, directory accessibility checks and inspection of listening ports.

Following the baseline assessment, the laboratory implemented the following controls:

- Retirement of the unnecessary legacy endpoint.
- Removal of archive content from the web document root.
- Restriction of archive directory permissions.
- Disabling of automatic directory listings in Nginx.
- Explicit denial of requests to the previous archive URL.
- Source-based UFW firewall restrictions.
- Monitoring of Nginx access logs and UFW firewall events.
- Protected backup and restoration of approved portal content.
- SHA-256 file-integrity verification.

The financial and governance exercises additionally considered avoidance, mitigation, transfer and temporary risk acceptance.

1.3 Principal Assessment Outcomes

The following table summarises the verification outcomes and the corresponding evidence that must support each conclusion.

Assessment area	Required outcome	Evidence
Baseline	Original service and archive exposures established	Baseline Nmap and curl outputs
Legacy service	Port 8080 no longer listening	Systemd status, Nmap and curl
Approved web service	Portal remains available	HTTP response
Archive protection	Old archive URL denied	HTTP responses and permissions
Firewall	Approved source permitted	UFW rules and successful request
Firewall	Unapproved source blocked	Blocked request and corresponding log where available
Detection	Application and firewall events investigated	Nginx and UFW log extracts
Backup	Portal content archived	Backup archive listing
Recovery	Deleted portal file restored	Restoration output and SHA-256 verification
Governance	Four treatment strategies evaluated	Treatment decision records
Financial assessment	First-year costs and illustrative ALE calculated	Calculation workbook

Actual measured results: [Insert verified summary from the laboratory evidence package.]

1.4 Overall GRC Assessment

The practical demonstrates the importance of linking technical implementation with formal risk management.

A control is not considered effective solely because it has been configured. Its effectiveness must be established through an appropriate validation procedure and supporting evidence.

The exercise also demonstrates that the removal of one security exposure does not eliminate all risks associated with an information system.

The remaining risk must therefore be reassessed, assigned to an accountable owner, monitored and reviewed periodically.

2. INTRODUCTION

2.1 Background

Information systems that support internal business operations require appropriate security controls to protect confidentiality, integrity and availability.

An internal document server may contain operational records, business documentation and information required by authorised personnel.

However, unnecessary services, excessive file permissions, unrestricted network access and inadequate backup arrangements can increase the likelihood of security incidents.

Effective cybersecurity governance requires organisations to identify these weaknesses and select appropriate risk treatment strategies.

The GRC103 Module 3 practical focuses on the implementation and validation of security controls rather than theoretical recommendations alone.

2.2 Laboratory Scenario

Northbridge Services operates a fictional internal document server.

The server initially contains:

- An approved internal web portal.
- An archive directory containing fictional training records.
- An unnecessary legacy endpoint.
- A web service that permits automatic directory listings.

Management requires the organisation to reduce these security exposures without interrupting the approved web service.

The laboratory therefore examines the risks associated with unnecessary service exposure, public availability of internal records, inadequate network restrictions and possible loss of portal information.

2.3 Purpose of the Assessment

The assessment was conducted to demonstrate the practical application of risk treatment principles within a controlled Linux environment.

The practical also aimed to demonstrate how a GRC professional can translate identified risks into implementable technical controls and subsequently assess whether those controls achieve their intended objectives.

2.4 Laboratory Objectives

The specific objectives were to:

1. Establish a baseline of exposed services and identify associated vulnerabilities.
2. Document the original security condition and assess the identified risks.
3. Retire an unnecessary legacy service.
4. Confirm the continued availability of the approved web portal.
5. Protect the archive directory from unauthorised network access.
6. Configure source-based firewall restrictions.
7. Validate permitted and blocked network requests.
8. Review relevant security logs.
9. Back up and restore a deleted laboratory file.
10. Verify restored-file integrity using SHA-256.
11. Calculate and compare treatment costs.
12. Evaluate avoidance, mitigation, transfer and acceptance.
13. Reassess residual risks.
14. Develop monitoring and operational handover requirements.

3. SCOPE AND LIMITATIONS

3.1 Scope

The scope was limited to the Northbridge Services laboratory environment.

Scope area	Description
Server	Ubuntu Server 24.04 LTS
Testing workstation	Kali Linux
Web service	Nginx
Firewall	UFW
Legacy service	Python HTTP server
Network testing	TCP port scanning and HTTP requests
Access controls	Linux file permissions and Nginx access rules

Logging	Nginx and UFW
Backup	Linux tar archive
Integrity verification	SHA-256
Risk assessment	Four identified laboratory risks
Financial assessment	Supplied fictional treatment costs and ALE assumptions

3.2 Out-of-Scope Activities

The following activities were excluded:

- Testing against production infrastructure.
- Testing systems belonging to third parties.
- Public internet exposure of the laboratory.
- Use of real customer or employee information.
- Testing outside the authorised laboratory network.
- Deployment of actual third-party backup services.
- Execution of a real organisational risk acceptance approval.

4. LABORATORY ENVIRONMENT AND ARCHITECTURE

4.1 Technical Environment

The practical used two virtual machines connected through an isolated host-only or internal virtual network.

This arrangement enabled the testing machine to communicate with the target server without exposing the intentionally vulnerable laboratory services to a public network.

4.2 Virtual Machine Configuration

Specification	Ubuntu Server	Kali Linux
Operating system	Ubuntu Server 24.04 LTS	Kali Linux
CPU	2 vCPUs	2 vCPUs
RAM	2–4 GB	2–4 GB

Storage	25 GB	25 GB
Network	Host-only/internal	Host-only/internal
Laboratory role	Target server	Testing workstation

4.3 Network Architecture

The logical communication arrangement was:

Kali Linux → Isolated Laboratory Network → Ubuntu Server

Kali Linux functioned as the testing workstation, while Ubuntu hosted the approved portal and the intentionally unnecessary legacy service.

The laboratory was configured without bridged networking or public service exposure.

A clean virtual-machine checkpoint was created before the practical changes.

4.4 Tools and Technologies

Tool or technology	Function
Ubuntu Server 24.04	Target server operating system
Kali Linux	Security testing environment
Nginx	Hosting the internal document portal
UFW	Host-based firewall
Python 3	Running the laboratory legacy endpoint
Nmap	Identifying exposed network ports
curl	Testing HTTP responses
systemd	Managing the legacy service
ss	Inspecting listening sockets
tar	Creating and restoring backup archives
SHA-256	Verifying restored-file integrity
journalctl	Reviewing system and firewall events

Linux permissions	Restricting filesystem access

5. RISK ASSESSMENT METHODOLOGY

5.1 Assessment Approach

The laboratory adopted a structured risk assessment and treatment process.

The process involved:

1. Identifying assets.
2. Identifying threats and weaknesses.
3. Assessing likelihood and impact.
4. Calculating initial risk scores.
5. Selecting appropriate treatment strategies.
6. Implementing security controls.
7. Validating control behaviour.
8. Reassessing residual risks.
9. Assigning ownership and monitoring requirements.

5.2 Risk Identification

Four principal risks were established.

Risk ID	Risk description	Affected asset
R1	Unnecessary legacy-service exposure	Ubuntu document server
R2	Unauthorised access to the archive	Fictional document records
R3	Unauthorised network access	Internal web portal
R4	Loss of approved portal content	Public portal directory

5.3 Risk Scoring Method

The laboratory uses a qualitative 1–5 scale for likelihood and impact.

Risk is calculated using:

Risk Score = Likelihood × Impact

Where:

- Likelihood represents the assessed possibility of the risk event occurring.
- Impact represents the assessed severity of the consequences.

5.4 Risk Classification

Risk score	Classification
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

These thresholds are supplied by the practical brief and represent classroom risk assessment criteria.

The resulting scores are ordinal and must not be converted into monetary loss estimates.

6. BASELINE SECURITY ASSESSMENT

6.1 Baseline Environment Establishment

The baseline assessment was conducted before the introduction of the security treatments.

This established the initial security configuration against which subsequent changes could be evaluated.

The Ubuntu server was configured with:

- A public portal directory.
- An archive directory.
- A separate legacy-service directory.
- An Nginx web server.
- A Python-based legacy endpoint.

The approved portal and fictional archive were initially placed under the same Nginx document root.

6.2 Exposed-Service Assessment

Nmap was used from Kali Linux to assess TCP ports 80 and 8080.

The baseline command was:

```
None
nmap -sT -p 80,8080 "$SERVER_IP" -oN baseline-ports.txt
```

The assessment examined:

Port	Intended service	Security significance
TCP 80	Nginx HTTP portal	Approved business service
TCP 8080	Python HTTP server	Unnecessary legacy service

Actual baseline scan results:

[Insert the complete or relevant redacted output from baseline-ports.txt.]

6.3 Web Application Assessment

The root web directory was tested using curl.

```
None
curl -i "http://$SERVER_IP/"
```

The initial Nginx configuration enabled automatic directory listings.

This represented an information-disclosure weakness because a remote client could potentially identify available directory and file names.

Observed result: [Insert actual HTTP status and response details.]

6.4 Archive Accessibility Assessment

The archive directory was tested through:

```
None
curl -i "http://$SERVER_IP/archive/"
```

The direct file was tested using:

```
None
curl -i "http://$SERVER_IP/archive/dummy-records.txt"
```

The laboratory brief identifies directory listing and direct retrieval as the intended baseline exposures.

The actual observations must be supported by:

- Baseline directory response.
- Direct-file response.
- Screenshot evidence.
- Corresponding command output files.

6.5 Legacy-Service Exposure

The unnecessary service was hosted through Python's HTTP server using TCP port 8080.

The endpoint was tested with:

```
None
curl -i "http://$SERVER_IP:8080/"
```

The server's listening sockets were also inspected with:

```
None
sudo ss -lntp
```

This assessment was intended to confirm whether the additional service was running and reachable from Kali.

Observed legacy-service result: [Insert actual result.]

6.6 Initial Risk Register

The following register establishes the four required baseline risks.

ID	Risk	Threat event	Observed weakness	Likelihood	Impact	Initial score	Evidence
R1	Legacy service exposure	Unauthorised use of unnecessary service	Service listening on TCP 8080	4	3	12	Baseline Nmap and curl

R2	Exposed archive	Unauthorised access to fictional records	Directory listing and direct retrieval	4	4	16	Baseline archive outputs
R3	Unauthorised network access	Unapproved client connects to portal	No effective source-based restriction at baseline	4	4	16	UFW and connectivity evidence
R4	Portal content loss	Accidental deletion or loss of portal information	Recovery capability not yet demonstrated	3	4	12	Baseline recovery assessment

The actual likelihood and impact values were determined using the 1–5 scale.

The resulting scores and classifications must reflect the documented assessment rather than assumed values.

7. RISK TREATMENT STRATEGY 1 – AVOIDANCE

7.1 Risk Description

Risk R1 concerned the unnecessary legacy endpoint exposed through TCP port 8080.

The legacy service did not form part of the approved business portal.

Maintaining an unnecessary network-accessible service increases the attack surface and creates an additional potential entry point.

7.2 Treatment Decision

The selected treatment was **avoidance**.

Avoidance was appropriate because the organisation did not require the legacy workflow.

The selected approach was to remove the unnecessary service from operation while preserving the approved Nginx portal.

7.3 Implementation

The service was managed through systemd.

The implementation command was:

```
None
sudo systemctl disable --now grc-legacy
```

The service state was subsequently checked with:

```
None
sudo systemctl is-active grc-legacy
```

The enablement state was inspected with:

```
None
sudo systemctl is-enabled grc-legacy
```

Listening sockets were inspected using:

```
None
sudo ss -lntp
```

7.4 Technical Validation

The service retirement was validated through:

1. Systemd service status.
2. Service enablement status.
3. Ubuntu listening-port inspection.
4. A repeat Nmap scan from Kali.
5. A repeat curl request to TCP 8080.
6. A continuity test against the approved portal.

The post-treatment scan command was:

```
None
nmap -sT -p 80,8080 "$SERVER_IP" -oN avoidance-ports.txt
```

The legacy endpoint was tested using:

```
None
curl -i --connect-timeout 5 \
"http://$SERVER_IP:8080/"
```

The approved portal was checked using:

```
None
curl -i "http://$SERVER_IP/public/"
```

7.5 Results Record

Validation test	Outcome	Evidence
Legacy systemd active state	Inactive	Service status
Legacy enablement	Disabled	systemctl output
TCP 8080	No longer open	Post-treatment Nmap
Legacy HTTP request	Connection unavailable	curl output
Approved portal	HTTP 200	curl output

7.6 Business Impact and Service Continuity

The selected treatment removed a service that was unnecessary for the intended business operation.

The main continuity requirement was that retiring port 8080 must not disrupt the approved portal on port 80.

The service continuity validation was therefore an essential part of the change.

Avoidance reduces the exposure associated with the retired workflow but does not remove every risk associated with the remaining server.

7.7 Rollback Considerations

The documented rollback command was:

```
None
sudo systemctl enable --now grc-legacy
```

If the rollback procedure was executed, the evidence must record when it was performed and when the security treatment was reapplied.

The final configuration is required to leave the legacy endpoint inactive and disabled.

Treatment conclusion: Avoidance was selected to remove the unnecessary legacy workflow rather than retain an unnecessary service requiring ongoing security maintenance.

8. RISK TREATMENT STRATEGY 2 – MITIGATION

8.1 Archive Protection

Risk R2 concerned the exposure of fictional records through the Nginx document root.

The original archive directory was:

```
None
/var/www/grc-lab/archive/
```

Because this directory was within the document root and directory listing was enabled, the records could be accessed through web requests.

The mitigation approach involved removing the archive from web publication and applying access restrictions.

8.2 Archive Relocation

The private storage directory was created using:

```
None
sudo mkdir -p /srv/grc-private
```

The archive was moved:

```
None
sudo mv /var/www/grc-lab/archive /srv/grc-private/
```

The new location was:

```
None
/srv/grc-private/archive/
```

This removed the archive from the normal Nginx document root.

8.3 File-System Access Restrictions

Directory permissions were restricted using:

```
None
sudo chmod -R go-rwx /srv/grc-private
```

The resulting permissions were inspected using:

```
None
sudo ls -ld /srv/grc-private
```

The full path permissions were inspected using:

```
None
sudo namei -l \
/srv/grc-private/archive/dummy-records.txt
```

These controls reduce the availability of the protected content to unauthorised local users.

8.4 Nginx Security Configuration

The Nginx configuration was updated to disable automatic directory listings and deny requests to the old archive URL.

The intended configuration was:

```
None
server {
   listen 80;
```

```
    server_name _;
    root /var/www/grc-lab;

    access_log /var/log/nginx/grc_access.log combined;
    error_log /var/log/nginx/grc_error.log;

    location / {
        autoindex off;
    }

    location /archive/ {
        deny all;
    }
}
```

The configuration was checked using:

```
None
sudo nginx -t
```

Following successful validation, Nginx was reloaded:

```
None
sudo systemctl reload nginx
```

8.5 Access-Control Validation

The following requests were conducted from Kali.

Test	Resource	Status
AR-01	/public/	200
AR-02	/archive/	403
AR-03	/archive/dummy-records.txt	403
AR-04	/	403

The public portal was expected to remain available while the archive and automatic directory listings were restricted.

8.6 Security Significance

Disabling automatic directory listing alone does not guarantee that known files cannot be retrieved directly.

A user who already knows a filename may still attempt to request it directly.

Consequently, the implementation combined:

- Archive relocation.
- File-system permission restrictions.
- Nginx directory-listing restrictions.
- Explicit denial of the previous archive URL.

Treatment conclusion: The combined preventive controls were intended to reduce the likelihood of unauthorised archive disclosure while preserving access to the approved portal.

9. UFW FIREWALL IMPLEMENTATION AND VALIDATION

9.1 Control Objective

Risk R3 concerned unrestricted incoming network access.

The security objective was to permit the approved Kali source address to access the web portal while blocking requests originating from an unapproved source address.

9.2 Firewall Configuration

The firewall configuration used the following commands:

```
None
sudo ufw default deny incoming
```

```
None
sudo ufw default allow outgoing
```

The approved Kali address was permitted using:

```
None
sudo ufw allow from "$KALI_IP" \
to any port 80 proto tcp
```

Firewall logging was enabled:

```
None
sudo ufw logging on
```

The firewall was activated:

```
None
sudo ufw enable
```

9.3 Firewall Rule Verification

The resulting configuration was inspected using:

```
None
sudo ufw status numbered
```

And:

```
None
sudo ufw status verbose
```

The intended policy was:

Firewall setting	Intended configuration
Default incoming	Deny
Default outgoing	Allow
Approved Kali source	Allow TCP port 80
Other incoming sources	Deny unless explicitly permitted
Logging	Enabled

Actual configuration evidence must be included in the appendix.

9.4 Approved-Source Testing

The approved Kali source was used to request the public portal.

```
None
curl -i "http://$SERVER_IP/public/"
```

The expected response was HTTP 200.

This test establishes whether the permitted source can access the approved application.

9.5 Blocked-Source Testing

The practical brief permitted the use of a second unused address on Kali for blocked-source testing.

The additional IP was assigned to the isolated network interface and used as the source address for a separate request.

The test command was:

```
None
curl --interface SECOND_SOURCE_IP \
--connect-timeout 5 \
"http://$SERVER_IP/public/"
```

After testing, the additional address was removed.

The temporary address was not intended to remain part of the final laboratory configuration.

9.6 Validation Results

Test ID	Source	Resource	result
FW-01	Approved Kali IP	/public/	HTTP 200
FW-02	Unapproved second IP	/public/	Blocked
FW-03	Approved Kali IP	/public/ after temporary IP removal	HTTP 200

A blocked request must be supported by the UFW configuration and, where collected, corresponding firewall log evidence.

A timeout alone does not conclusively establish that UFW blocked the request.

9.7 Security Significance

The source-based firewall rule implements network-level access restrictions.

It limits which source address can establish a connection to the approved web service.

However, an IP-based rule is not equivalent to user authentication or encryption.

The organisation must therefore consider additional security requirements as the service develops beyond the isolated training environment.

Treatment conclusion: Source-based UFW restrictions are an important preventive control, but their effectiveness depends on correct rule configuration, validation and continued monitoring.

10. SECURITY MONITORING AND LOG CORRELATION

10.1 Monitoring Objectives

The laboratory included monitoring to establish whether application-level requests and network-level firewall events could be identified.

The objective was to distinguish between requests reaching Nginx and packets blocked by the firewall before reaching the application.

10.2 Nginx Access Logging

Nginx was configured to record requests using:

```
None
access_log /var/log/nginx/grc_access.log combined;
```

The access log was inspected using:

```
None
sudo tail -n 30 /var/log/nginx/grc_access.log
```

The log was used to investigate:

- Approved requests.
- Denied archive requests.
- Direct file-access attempts.
- Corresponding HTTP status codes.

10.3 Firewall Logging

UFW logging was enabled.

Recent firewall events were investigated with:

```
None
sudo journalctl -k \
--since '15 minutes ago' | grep 'UFW BLOCK'
```

Where available, the UFW log file was also inspected:

```
None
sudo tail -n 30 /var/log/ufw.log
```

The relevant fields included:

Field	Interpretation
SRC	Source address
DST	Destination address
PROTO	Network protocol
DPT	Destination port
UFW BLOCK	Firewall-blocking event

10.4 Log Correlation

The assessment distinguished application logging from firewall logging.

Requests that reach Nginx can generate access-log records, including requests that Nginx denies with an HTTP response.

Traffic blocked by UFW before reaching Nginx should not be treated as a normal HTTP request in the Nginx access log.

Consequently, firewall-blocked events should be investigated through the appropriate kernel or UFW logging source.

10.5 Security Event Validation Table

Test ID	Source IP	Request	Outcome
LOG-01	Approved source	/public/	HTTP 200 in Nginx log
LOG-02	Approved source	/archive/	HTTP 403 in Nginx log
LOG-03	Approved source	Direct archive file	HTTP 403 in Nginx log
LOG-04	Unapproved source	TCP 80	UFW block event where collected

Where a firewall event could not be collected, this must be disclosed as an evidence limitation.

A missing log record must not be replaced with an assumed event.

11. CORRECTIVE CONTROLS – BACKUP AND RECOVERY

11.1 Recovery Requirements

Risk R4 concerned the possible loss of approved portal content.

The laboratory introduced a backup and recovery exercise to demonstrate that deleted portal content could be restored.

The test involved creating a backup, recording the original file hash, deleting the portal file, restoring it and verifying its integrity.

11.2 Backup Implementation

A dedicated backup directory was created:

```
None
sudo mkdir -p /srv/grc-backups
```

Permissions were restricted:

```
None
sudo chmod 700 /srv/grc-backups
```

The public portal directory was backed up using:

```
None
sudo tar -czpf \
/srv/grc-backups/public-before-test.tgz \
-C /var/www/grc-lab public
```

The backup archive was inspected using:

```
None
sudo tar -tzf \
/srv/grc-backups/public-before-test.tgz
```

The expected archive contents included:

```
None
public/
public/index.html
```

11.3 Original File-Integrity Reference

The original file hash was generated using:

```
None
sha256sum \
/var/www/grc-lab/public/index.html \
| tee ~/portal-before.sha256
```

This established the integrity reference used during restoration.

SHA-256 provides a method of comparing the content of the restored file against the original file.

11.4 Simulated File Loss

The original portal file was deleted using:

```
None
sudo rm /var/www/grc-lab/public/index.html
```

The deletion was verified through a directory listing.

The approved portal was subsequently tested from Kali.

The simulated loss was intended to demonstrate the impact of accidental deletion on portal availability.

11.5 Restoration

The backup archive was extracted using:

```
None
sudo tar -xzpf \
/srv/grc-backups/public-before-test.tgz \
-C /var/www/grc-lab
```

The restored file was checked using:

```
None
sudo ls -l /var/www/grc-lab/public/
```

11.6 File-Integrity Verification

The integrity verification command was:

```
None
sha256sum -c ~/portal-before.sha256
```

The expected successful verification output was:

```
None
/var/www/grc-lab/public/index.html: OK
```

The OK result indicates that the restored file's calculated hash matches the original recorded hash.

Actual hash verification: [Insert actual command output.]

11.7 Service Restoration Verification

Kali was used to confirm that the approved portal was available following restoration.

```
None
curl -i "http://$SERVER_IP/public/"
```

The expected successful response was HTTP 200 with the original fictional portal content.

The measured recovery duration represents the time observed during this specific classroom recovery exercise.

It should not automatically be considered an organisation-wide Recovery Time Objective (RTO).

11.9 Backup Limitations

The backup was maintained on the same Ubuntu server as the original portal.

Although appropriate for a controlled file-deletion exercise, a same-host backup does not provide sufficient protection against complete host loss or severe server compromise.

The exercise therefore demonstrates the need to consider off-host or managed backup arrangements.

Treatment conclusion: Backup and restoration provide a corrective control that supports information availability and recovery following accidental file loss. Integrity verification adds assurance that the restored content matches its original state.

12. RISK TREATMENT STRATEGY 3 – TRANSFER

12.1 Managed Backup Assessment

The practical brief supplied a fictional managed-backup service offer for evaluation.

The offer consists of:

Cost component	Amount
Setup cost	$120

Monthly service charge	$20
Number of months	12

The objective is to assess whether using a third-party provider offers an additional recovery capability compared with relying only on local server backup.

12.2 Financial Evaluation

Annual recurring service cost:

$20 × 12 = $240

First-year total:

$120 + $240 = **$360**

This figure represents the supplied fictional service price.

12.3 Provider Responsibilities

The proposed managed-backup provider would be expected to accept clearly defined contractual responsibilities concerning:

- Backup storage services.
- Contractually agreed backup operations.
- Service availability.
- Security requirements.
- Relevant incident notification.
- Agreed data-retention requirements.
- Restoration support within the contractual scope.

These responsibilities must be formally documented and verified before an actual service is engaged.

12.4 Customer Responsibilities

Northbridge Services would retain responsibility for:

- Identifying information requiring backup.
- Defining backup scope.
- Managing access to backup information.
- Reviewing service assurance evidence.
- Conducting restoration tests.
- Maintaining appropriate retention arrangements.
- Assessing the provider's security posture.
- Monitoring third-party performance.

- Managing its own recovery requirements.

12.5 Proposed Contractual Clause

Proposed managed-backup service clause

The service provider shall maintain the agreed backup storage service and perform backup activities in accordance with the documented service scope, security requirements and retention schedule.

The provider shall notify Northbridge Services of relevant service disruptions and security incidents within the agreed contractual notification period.

Northbridge Services shall retain responsibility for defining backup scope, managing authorised access, reviewing backup evidence and conducting periodic restoration tests.

The parties shall agree on restoration requirements, evidence retention, service availability and responsibilities before service commencement.

This clause is proposed for academic evaluation only and does not represent an executed agreement.

12.6 Third-Party Risk Considerations

Transfer does not eliminate the underlying operational risk.

Northbridge Services would still need to consider:

- Provider reliability.
- Service availability.
- Backup recoverability.
- Data protection responsibilities.
- Contractual limitations.
- Third-party security incidents.
- Continued access to business information.

A managed backup arrangement can transfer certain operational responsibilities while leaving organisational accountability and assurance obligations with the customer.

Treatment conclusion: Transfer is appropriate for evaluating additional external backup capabilities, but it does not remove the need for independent restoration testing and provider oversight.

13. RISK TREATMENT STRATEGY 4 – ACCEPTANCE

13.1 Risk Description

The practical brief requests an assessment of whether plain HTTP can be temporarily retained on the isolated laboratory network.

The issue concerns unencrypted HTTP communication between the testing client and the server.

13.2 Acceptance Justification

The classroom scenario permits consideration of temporary HTTP retention because:

- The laboratory is isolated.
- The content is fictional.
- No real customer information is used.
- The service is restricted to the training environment.
- The acceptance is time-limited.

However, plain HTTP does not encrypt information in transit.

The limited laboratory context reduces the scope of exposure but does not remove the underlying confidentiality concern.

13.4 Conditions of Acceptance

The acceptance is conditional upon:

1. Continued use of the isolated network.
2. Use of fictional laboratory data only.
3. No public exposure of the service.
4. No use of the service for real sensitive information.
5. Review before the 14-day expiry.
6. Implementation of further treatment where operational use is proposed.

13.5 Triggers for Immediate Reassessment

Immediate review is required if:

- Real information is introduced.
- External connectivity is enabled.
- The portal is expanded beyond the original scope.
- New users or systems obtain access.

- The network design changes.
- The approval period expires.

The simulated acceptance does not represent permission to deploy HTTP as a permanent security arrangement.

Treatment conclusion: Acceptance may be considered only within the explicitly defined and time-limited laboratory conditions. Continued use beyond those boundaries requires reassessment or additional treatment.

14. FINANCIAL ANALYSIS AND COST-BENEFIT EVALUATION

14.1 First-Year Cost Assessment

The practical brief provides three fictional investment options.

The purpose is to compare the first-year cost of different control implementations.

14.2 Option A – Hardening Work

Supplied assumptions:

- Four hours of work.
- Labour rate of $25 per hour.
- Annual maintenance of $50.

Labour cost:

4 × $25 = $100

First-year cost:

$100 + $50 = **$150**

14.3 Option B – Managed Backup

Supplied assumptions:

- Setup cost of $120.
- Monthly cost of $20.

Annual recurring cost:

$20 × 12 = $240

First-year cost:

$120 + $240 = **$360**

14.4 Option C – TLS Deployment

Supplied assumptions:

- Three hours of work.
- Labour rate of $25 per hour.
- Annual maintenance of $25.

Labour cost:

3 × $25 = $75

First-year cost:

$75 + $25 = **$100**

14.5 First-Year Cost Comparison

Option	Setup	Labour	Annual recurring cost	First-year cost
A – Hardening	$0	$100	$50	$150
B – Managed backup	$120	$0	$240	$360
C – TLS deployment	$0	$75	$25	$100
Total combination	**$120**	**$175**	**$315**	**$610**

14.6 Recommended Investment Combination

The recommended combination is A + B + C.

The total first-year cost is:

$150 + $360 + $100 = **$610**

The recommended combination addresses several distinct areas of risk.

Option	Security benefit

A – Hardening	Reduces exposure through technical security configuration
B – Managed backup	Adds a proposed external backup capability
C – TLS deployment	Provides transport encryption for the approved portal

Hardening, backup and encryption provide complementary security benefits.

The organisation should assess the operational requirements and implement TLS before expanding the portal beyond the isolated HTTP laboratory arrangement.

14.7 Excluded Costs

The fictional financial model does not expressly include:

- Taxes.
- Hardware.
- Additional software licensing.
- Training.
- Data migration.
- Downtime.
- Additional staffing.
- Incident-response costs.
- Future service expansion.

These exclusions must be considered before any real organisational investment decision.

14.8 Annual Loss Expectancy

A separate illustrative scenario was provided in the practical brief.

The scenario assumes:

Input	Assumption
Annual Rate of Occurrence (ARO)	0.2
Baseline Single Loss Expectancy (SLE)	$5,000
Residual Single Loss Expectancy	$1,000

The ALE formula is:

ALE = ARO × SLE

Baseline ALE

0.2 × $5,000 = **$1,000**

Residual ALE

0.2 × $1,000 = **$200**

Annual Financial Benefit

$1,000 − $200 = **$800**

First-Year Net Benefit

Managed backup first-year cost = $360.

$800 − $360 = **$440**

14.9 Financial Analysis Summary

Metric	Result
Baseline ALE	$1,000
Residual ALE	$200
Assumed annual benefit	$800
Managed backup first-year cost	$360
First-year illustrative net benefit	**$440**

14.10 Interpretation

Under the supplied assumptions, the illustrative recovery control produces an estimated annual benefit of $800 against a first-year managed-backup cost of $360.

This produces an illustrative first-year net benefit of $440.

However, the assumptions have not been established through actual loss statistics or financial records.

The successful laboratory restoration test cannot independently prove the assumed annual occurrence rate or reduction in financial loss.

The financial calculation must therefore be presented as an illustrative classroom scenario rather than a measured organisational return on investment.

15. RESIDUAL RISK ASSESSMENT

15.1 Purpose

Residual risk represents the risk remaining after the selected treatment controls have been implemented.

It is important because a successfully implemented control does not necessarily eliminate all associated threats.

The reassessment therefore considers both control effectiveness and remaining limitations.

15.3 Remaining Security Concerns

R1 – Legacy Service

Although the unnecessary service was retired, future configuration changes could re-enable it.

Periodic configuration-drift checks are therefore necessary.

R2 – Archive Exposure

The archive relocation and access restrictions reduce the risk of unauthorised publication.

However, administrators must continue to review file permissions, Nginx configuration and changes to the document root.

R3 – Network Access

The source-based firewall rule restricts network access.

However, IP-based restrictions should not be treated as a substitute for application authentication, strong identity controls or transport encryption.

R4 – Portal Content Loss

The laboratory demonstrates recovery from a single-file deletion scenario.

However, same-host backup storage leaves the organisation exposed to complete host loss or compromise.

An independent backup location is therefore recommended.

15.4 Residual Risk Acceptance

Any residual risk outside the organisation's approved appetite should be escalated to the designated risk owner.

The risk register should identify:

- Remaining exposure.
- Residual score.
- Control evidence.
- Owner.
- Review date.
- Escalation trigger.
- Further treatment requirement.

16. MONITORING AND OPERATIONAL HANDOVER

16.1 Monitoring Requirements

Security controls require ongoing verification to detect failures, configuration drift and emerging risks.

The laboratory establishes proposed monitoring activities for Northbridge Services.

16.2 Monitoring Matrix

Monitoring activity	Owner	Frequency	Measurement	Threshold	Escalation
Portal availability	System Administrator	Every 5 minutes	HTTP response	HTTP 200 required	Escalate after two consecutive failures
Unexpected open ports	Security/GRC Analyst	Daily	Compare approved and discovered ports	Any unexplained open port	Investigate immediately
Backup and restoration	Backup Administrator	Monthly	Restore and SHA-256 verification	Successful restoration required	Escalate failed recovery

Legacy-service configuration drift	System Administrator	Weekly	systemd active and enabled state	Must remain inactive and disabled	Investigate immediately

These are proposed operational thresholds for management consideration, not measurements obtained from the laboratory.

16.3 Portal Availability Monitoring

The proposed technical check is:

```
None
curl -sS -o /dev/null \
-w '%{http_code}\n' \
http://SERVER_IP/public/
```

A successful application response should return HTTP 200.

16.4 Legacy-Service Monitoring

The configuration should be checked using:

```
None
sudo systemctl is-active grc-legacy
```

And:

```
None
sudo systemctl is-enabled grc-legacy
```

The intended final states are inactive and disabled.

16.5 Port Monitoring

An authorised Nmap scan can be used to identify unexpected open services.

The results should be compared with the approved service inventory.

Any unexplained service should be investigated.

16.6 Recovery Monitoring

A recurring restoration exercise should verify:

- Backup availability.
- Archive integrity.
- Successful extraction.
- File integrity.
- Portal availability after restoration.
- Achievement of the approved recovery time objective.

Monitoring must use a test copy where possible to avoid disrupting production content.

17. CHANGE MANAGEMENT AND ROLLBACK

17.1 Change Control Requirements

Technical risk treatment should be performed through a documented change process.

The practical required proposed changes, validation procedures and rollback arrangements.

All academic approval records are labelled simulated.

17.2 Change Register

Change ID	Description	Result	Validation evidence
CHG-001	Retire legacy service	TCP 8080 unavailable	systemd, Nmap and curl
CHG-002	Protect archive	Archive no longer accessible through previous URL	Nginx tests and curl
CHG-003	Restrict network access	Only approved source permitted on TCP 80	UFW and client testing
CHG-004	Backup and recovery	Portal content recoverable	SHA-256 and HTTP verification

17.3 Rollback Procedures

CHG-001: Legacy Service

```
None
sudo systemctl enable --now grc-legacy
```

After any temporary rollback test, the security treatment must be reapplied:

```
None
sudo systemctl disable --now grc-legacy
```

CHG-002: Archive Protection

The previous Nginx configuration can be restored from the documented configuration backup.

The previous archive location can be re-established on the disposable laboratory VM if required.

However, the previous configuration is intentionally insecure and should not remain in place.

CHG-003: Firewall

From the Ubuntu VM console:

```
None
sudo ufw disable
```

This is an emergency rollback procedure for the disposable laboratory VM.

The intended firewall rules must subsequently be reapplied and validated.

CHG-004: Portal Recovery

```
None
sudo tar -xzpf \
/srv/grc-backups/public-before-test.tgz \
-C /var/www/grc-lab
```

Restoration should be followed by integrity verification.

17.4 Change Management Conclusion

The use of change records supports traceability and accountability.

It ensures that technical changes have a documented purpose, expected outcome, validation method and recovery procedure.

Planned rollback procedures must be clearly distinguished from rollback activities actually executed during the practical.

19. MANAGEMENT RECOMMENDATIONS

Based on the risk treatment activities required by the practical, the following recommendations are proposed for Northbridge Services.

19.1 Maintain Service Minimisation

Unnecessary services should be removed to reduce the attack surface.

The retirement of the legacy endpoint should be maintained through configuration-drift monitoring.

19.2 Enforce Least-Privilege Access

Sensitive information should not be stored in publicly accessible web directories without a justified business requirement.

File-system permissions and application-level access rules should be reviewed periodically.

19.3 Maintain Network Segmentation and Firewall Restrictions

The approved source-based access rules should be maintained and reviewed.

Any changes to the authorised client inventory should follow the organisation's change-management procedures.

19.4 Strengthen Transport Security

TLS should be implemented before the portal is used beyond the isolated training environment.

Temporary HTTP acceptance should be reviewed at the specified 14-day expiry.

19.5 Adopt Independent Backup Storage

The same-host backup arrangement should be supplemented by an independent managed or off-host backup capability.

Provider assurance, contractual requirements, restoration testing and evidence retention should form part of third-party oversight.

19.6 Formalise Recovery Objectives

Management should define suitable recovery time and recovery point objectives based on business requirements.

The classroom recovery duration should not automatically become an enterprise recovery objective.

19.7 Improve Security Monitoring

The organisation should monitor:

- Approved portal availability.
- Unexpected open ports.
- Firewall-denied requests.
- Nginx access events.
- Legacy-service configuration.
- Backup and recovery success.

19.8 Maintain Formal Risk Ownership

Each identified risk should have a designated risk owner.

Residual risks must be reviewed at defined intervals and escalated when they exceed the organisation's accepted risk appetite.

20. CONCLUSION

The GRC103 Module 3 Technical Risk Treatment Laboratory demonstrates how identified information-security risks can be translated into practical control implementation, validation and management decisions.

The Northbridge Services scenario required the assessment of four principal risks involving unnecessary service exposure, archive accessibility, unauthorised network access and potential loss of approved portal content.

The exercise applied the four recognised treatment approaches required by the practical brief.

Avoidance was represented by the retirement of the unnecessary legacy endpoint.

Mitigation was represented by archive protection, Nginx access restrictions, source-based UFW firewall controls and backup/recovery measures.

Transfer was assessed through a fictional managed-backup service arrangement, including first-year costs and proposed contractual responsibilities.

Acceptance was evaluated in relation to temporary HTTP use within the restricted laboratory environment.

The practical also demonstrated the importance of validating security controls through technical evidence rather than relying solely on written recommendations.

The baseline and post-treatment comparisons, application and firewall logs, backup restoration and integrity verification provide the basis for evaluating control effectiveness.

The financial assessment further demonstrates how risk-treatment costs and illustrative Annual Loss Expectancy can support management decision-making, provided that assumptions are clearly distinguished from measured results.

Ultimately, effective GRC engineering requires the integration of technical implementation, risk governance, operational monitoring, evidence management and management accountability.

The laboratory therefore reinforces the principle that security controls must not only be implemented but also tested, documented, monitored and periodically reassessed.

21. REFERENCES

The following references are drawn from the official practical brief and the technical documentation identified in the assignment.

[1] International Cybersecurity and Digital Forensics Academy (ICDFA). (n.d.). *GRC103 Risk Assessment and Management Techniques: Module 3 – Risk Treatment Strategies*. Course learning material and official Technical Risk Treatment Laboratory brief.

[2] Canonical. (n.d.). *Ubuntu Server documentation: Firewall*. Ubuntu Server documentation.
https://ubuntu.com/server/docs/firewalls/

[3] NGINX, Inc. (n.d.). *Module ngx_http_autoindex_module*. NGINX documentation.
https://nginx.org/en/docs/http/ngx_http_autoindex_module.html

[4] NGINX, Inc. (n.d.). *Module ngx_http_log_module*. NGINX documentation.
https://nginx.org/en/docs/http/ngx_http_log_module.html